BƯỚC 42 - PERSISTED QUERIES / TRUSTED DOCUMENTS

Bản tiếng Việt - triển khai cụ thể + Zusammenfassung Code

1. Mục tiêu

Production client không gửi GraphQL document tùy ý. Các operation được đăng ký trước trong OperationStore; runtime gửi operationId + variables. Trusted Documents tạo allowlist cho các operation được phép chạy.

2. Điều kiện

GraphQL::Pro::OperationStore thuộc GraphQL Pro. Nếu project chưa dùng GraphQL Pro, hãy coi đây là bước production-hardening và chưa cần tự viết một StoredQuery system thay thế.

3. Cấu hình Schema

Thêm OperationStore vào schema. Nếu có tracing/APM, đặt tracing trước OperationStore.

```
class YourAppSchema < GraphQL::Schema
  query Types::QueryType
  mutation Types::MutationType

  use GraphQL::Dataloader

  # Tracing/APM (n□u có) đặt trước OperationStore
  use GraphQL::Pro::OperationStore
end
```

4. Backend lưu trữ

OperationStore có thể dùng ActiveRecord hoặc Redis. Với Rails + PostgreSQL, ActiveRecord là lựa chọn dễ học. Không tự đoán schema bảng; dùng generator/hướng dẫn đúng với version GraphQL Pro của project.

5. Routes

Thêm GraphQL endpoint, OperationStore Sync API và Dashboard. Dashboard production phải được bảo vệ bằng admin authentication; không expose công khai.

```
# config/routes.rb
using GraphQL::Pro::Routes

Rails.application.routes.draw do
  post "/graphql", to: "graphql#execute"

  # Production: b□o vệ dashboard bằng admin authentication
  mount YourAppSchema.dashboard,
        at: "/graphql/dashboard"

  mount YourAppSchema.operation_store_sync,
        at: "/graphql/sync"
end
```

6. Tổ chức operations frontend

Tách các operation thành file .graphql, ví dụ GetProjects.graphql, GetTasks.graphql, CreateTask.graphql, UpdateTask.graphql. Mỗi operation nên có Operation Name rõ ràng.

```
query GetTasks(
  $projectId: ID!
  $filter: TaskFilterInput
  $first: Int
  $after: String
) {
  tasks(
    projectId: $projectId
    filter: $filter
    first: $first
    after: $after
  ) {
    nodes {
      id
      title
      status
      priority
    }

    pageInfo {
      hasNextPage
```

```
      endCursor
    }
  }
}
```

7. Sync operations

Flow: *.graphql -> sync client/CLI -> /graphql/sync -> OperationStore. Sau khi sync, server biết trước các operation hợp lệ của client như project-web.

8. Runtime request

Sau khi operation đã được sync, client gửi operationId và variables. Variables vẫn dynamic; persisted query không hard-code projectId, filter hay pagination.

```
{
  "operationId": "project-web/abc123...",
  "variables": {
    "projectId": "10",
    "first": 20
  }
}
```

9. Trusted Documents

Production mong muốn: known operationId -> execute; unknown operationId -> reject; arbitrary raw query -> không cho chạy. Development/test có thể vẫn cho raw query để GraphiQL và RSpec thuận tiện.

10. Authorization vẫn bắt buộc

Trusted operation không có nghĩa trusted user. Mutation DeleteProject đã persist vẫn phải authenticate_user! và authorize! project, :destroy. OperationStore không thay Policy, Complexity, Pagination hay Rate Limiting.

11. Logging Bước 41

Có thể thêm operation_id vào structured log. Không dùng operationId để authorize và không log raw query/variables/token.

```
{
  operation: operation_name,
  operation_id: operation_id,
  request_id: request_id,
  user_id: user&.id,
  duration_ms: duration_ms
}
```

12. RSpec tối thiểu

Test 3 trường hợp: known operationId -> success; unknown operationId -> reject; known operation + unauthorized user -> Policy vẫn chặn. Không hard-code error message của OperationStore trước khi xác nhận behavior của version đang dùng.

13. Deploy order

Thứ tự an toàn: 1) deploy backend schema hỗ trợ operation mới; 2) sync persisted operations; 3) deploy frontend. Nếu frontend deploy trước khi sync, operationId mới có thể bị server coi là unknown.

14. Liên kết Bước 43

OperationStore giúp biết client nào đã đăng ký operation nào. Điều này hỗ trợ Schema Evolution: trước khi xóa field deprecated, kiểm tra còn trusted operation nào dùng field đó hay không.

Zusammenfassung - Code

Code cốt lõi cần nhớ:

```
class YourAppSchema < GraphQL::Schema
  query Types::QueryType
  mutation Types::MutationType

  use GraphQL::Dataloader

  # Tracing/APM (n□u có) đặt trước OperationStore
  use GraphQL::Pro::OperationStore
end

# config/routes.rb
using GraphQL::Pro::Routes

Rails.application.routes.draw do
```

```
  post "/graphql", to: "graphql#execute"

  # Production: b□o vệ dashboard bằng admin authentication
  mount YourAppSchema.dashboard,
        at: "/graphql/dashboard"

  mount YourAppSchema.operation_store_sync,
        at: "/graphql/sync"
end
```

```
{
  "operationId": "project-web/abc123...",
  "variables": {
    "projectId": "10",
    "first": 20
  }
}
```

Checklist

GraphQL Pro/OperationStore ✓ | backend persistence ✓ | /graphql/sync ✓ | dashboard admin-only ✓ | named .graphql operations ✓ | sync trước frontend deploy ✓ | known/unknown operation tests ✓ | Policy vẫn bắt buộc ✓ | operation_id logging tùy chọn ✓